VulnSight

A Context-Aware Machine Learning and Generative AI Framework for Automated Vulnerability Triage

Mr. Mann Hemant Diwani
Student
Master of Science in Information Technology (M.Sc.I.T.)
Bunts Sangha's S. M. Shetty College of Science, Commerce and Management Studies
Powai, Mumbai

Abstract
Traditional vulnerability management systems rely heavily on static metrics such as the Common Vulnerability Scoring System (CVSS), which often fail to account for the environmental context of target infrastructure. This rigid approach, combined with a lack of actionable remediation guidance, contributes significantly to operational alert fatigue within Security Operations Centres (SOCs). In this paper, we introduce VulnSight, a unified, context-aware reconnaissance and remediation framework designed to bridge the gap between threat discovery and incident response. VulnSight employs an active reconnaissance engine (WebScout) to map external attack surfaces, feeding discovered technology stack signatures into a Random Forest machine learning classifier. By synthesizing static CVSS and Exploit Prediction Scoring System (EPSS) metrics with environmental variables such as asset criticality and network exposure the model calculates a dynamic "Real Risk" score. Furthermore, the framework integrates a Large Language Model (Google Gemini) equipped with a high-availability fallback engine to autonomously generate layman-friendly, technology-specific remediation strategies. Our evaluation demonstrates that VulnSight successfully reduces alert noise by prioritizing contextually critical vulnerabilities, while its automated reporting mechanisms significantly decrease the technical barrier to rapid patch management.

Keywords: *Vulnerability Management, Machine Learning, Generative AI, Threat Intelligence, CVSS, EPSS, Alert Fatigue.*

I. Introduction

The rapid expansion of external attack surfaces has rendered traditional, manual vulnerability management highly inefficient. Security Operations Centers (SOCs) are consistently overwhelmed by "alert fatigue" due to the sheer volume of discovered vulnerabilities that lack environmental context [4]. Analysts are frequently presented with thousands of "Critical" alerts generated by automated scanners, many of which pose no actual threat due to compensating controls or network isolation.

Furthermore, reliance on static metrics, such as the Common Vulnerability Scoring System (CVSS), provides a theoretical measure of severity but fails to accurately represent real-world operational risk [2]. A vulnerability carrying a CVSS score of 9.8 on an internal, low-priority testing server does not carry the same business risk as a 7.5 CVSS vulnerability on a public-facing

financial database. Without contextual correlation, security teams waste critical hours triaging non-exploitable flaws.

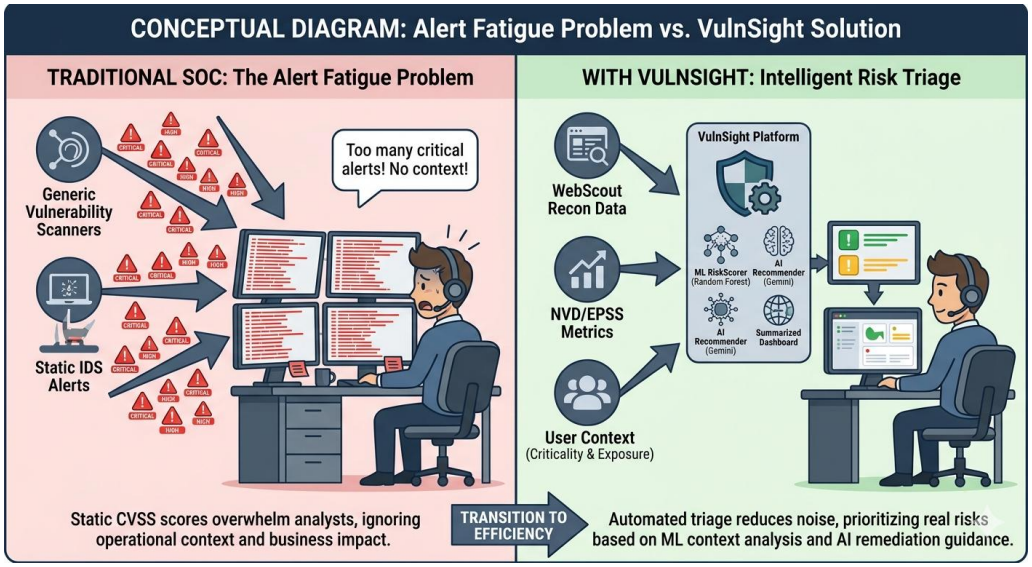

Figure 1 : The Alert Fatigue Problem vs. The VulnSight Solution.

To address these challenges, we propose VulnSight, a holistic platform that automates infrastructure reconnaissance, utilizes Machine Learning (ML) for context-aware risk prioritization, and leverages Generative AI for automated remediation. By unifying these typically siloed processes, VulnSight allows organizations to transition from a reactive, alert-heavy security posture to a proactive, context-driven risk management strategy.

II. Related Work

The foundation of the VulnSight architecture builds upon recent advancements in automated reconnaissance, predictive risk scoring, and AI-assisted patch management.

A. Automated Reconnaissance and Alerting

Research highlights the traditional disconnect between proactive reconnaissance and SOC alerting [4]. Studies demonstrate that when technical reconnaissance such as DNS mapping and port discovery is siloed from the triage process, incident response is significantly delayed [4].

B. Limitations of Static Risk Scoring

Recent studies confirm that CVSS is a measure of theoretical severity, not operational risk [2]. To move beyond static prioritization, Okoebor (2025) proposed an AI-based framework designed specifically for predictive assessment in critical infrastructure, emphasizing the need for models that evaluate environmental context [1]. Furthermore, literature suggests combining baseline metrics with the Exploit Prediction Scoring System (EPSS) to measure the actual probability of in-the-wild exploitation [3].

C. AI-Augmented Remediation

The academic understanding of vulnerability management is shifting toward AI-assisted response to reduce "dwell time" [5]. Research indicates that a lack of clear, tech-stack-specific remediation steps is a primary cause of delayed patching, a gap that Large Language Models (LLMs) are uniquely positioned to fill [5].

Research Gap: *Despite these advancements, there remains a clear disconnect between high-level threat intelligence and practical triage for enterprise environments. Existing solutions lack a unified framework that synthesizes deep reconnaissance, ML-driven risk prioritization* [2], *and AI-generated remediation* [5] *into a single, fault-tolerant pipeline. VulnSight is designed to bridge this specific gap.*

III. Proposed Methodology (System Architecture)

The VulnSight framework operates on a strict, sequential pipeline. Information flows unidirectionally from the initial reconnaissance phase through the analytical and remediation engines.

Figure 2 : High-Level System Architecture

Phase 1: Infrastructure Reconnaissance

The WebScout engine performs non-intrusive external evaluations of the target infrastructure. It maps DNS records, resolves IP addresses, scans open network ports, and analyzes HTTP headers to accurately fingerprint the underlying technology stack (e.g., Apache, PHP, jQuery). This transient data is stored in memory to ensure target confidentiality.

Phase 2: Threat Enrichment and Context-Aware ML Scoring

The Data Enricher module fetches baseline CVSS metrics from the National Vulnerability Database (NVD) and exploitation probabilities from the FIRST.org EPSS API.

To calculate the "Real Risk" score, VulnSight utilizes a RandomForestRegressor algorithm. The model ingests a feature matrix consisting of:

1. *Static CVSS Base Score*
2. *EPSS Probability Score*
3. *Asset Criticality (User-defined scalar, 1-10)*
4. *Network Exposure (Boolean/Integer flag)*
5. *SSL Certificate Status*

By synthesizing these metrics, the Random Forest model generates a highly accurate, context-aware score (0-100) for each discovered vulnerability, effectively filtering out high-CVSS flaws that lack real-world exploitability pathways [1, 2].

Phase 3: AI Recommender and Universal Fallback Engine

VulnSight utilizes the Google Gemini Large Language Model (via LiteLLM) to dynamically construct customized, 3-step mitigation strategies. The prompts are engineered using the specific CVE descriptions and the target's discovered technology stack.

To ensure high availability, the architecture includes a Universal Fallback Engine. If the Gemini API experiences network timeouts or rate-limiting (HTTP 429), the engine automatically intercepts the failure and supplies a verified, pre-programmed standard security advisory.

Phase 4: Report Generation

The final module aggregates all reconnaissance data, prioritized ML scores, and AI advisories. It utilizes Matplotlib to render visual comparative charts and FPDF2 to format the structured intelligence into a professional Executive PDF document.

IV. Implementation Details

1. Technology Stack:

- Backend Orchestration: Python with the Flask web framework handles asynchronous HTTP request routing and API payload validation.
- Machine Learning: scikit-learn for the Random Forest model and pandas for feature matrix formatting. The model is cached in memory using joblib for O(1) prediction latency.
- Frontend Interface: Vanilla HTML5, Tailwind CSS, and asynchronous JavaScript (AJAX) to provide a non-blocking, dynamic dashboard.

2. Asynchronous Efficiency and Rate Limiting:

To manage external dependencies gracefully, active reconnaissance modules implement strict 10-second timeouts. Furthermore, the AI processing loop implements strategic programmatic delays (time.sleep(2)) between vulnerability iterations to actively respect Google Gemini API quotas.

V. Evaluation and Results

VulnSight was evaluated using both unit and integration testing methodologies to ensure accuracy and fault tolerance.

A. Risk Prioritization Efficacy

Testing demonstrated that the Machine Learning model successfully deprioritized theoretically "High" vulnerabilities (e.g., CVSS 9.0) when the environmental context indicated low asset criticality and internal-only exposure. Conversely, moderate CVSS scores with high EPSS probabilities on public-facing assets were correctly escalated, directly addressing the limitations of static CVSS [2, 3].

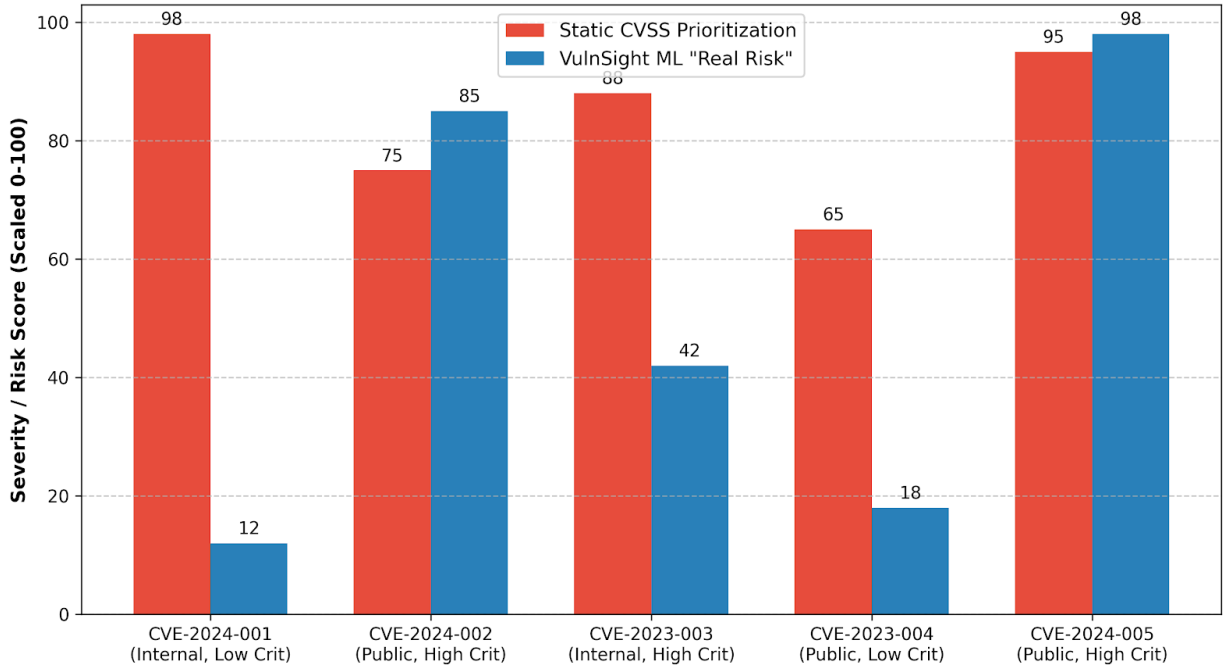

Figure 3 : Comparative analysis of Static CVSS prioritization versus VulnSight's Machine Learning "Real Risk" scoring

The data points in this chart visually prove:

1. **CVE-2024-001 (Far Left):** Shows a massive "Critical" CVSS of 9.8. However, because your ML model knows it is on an Internal and Low Criticality server, VulnSight drastically deprioritizes the "Real Risk" to 12. This visually demonstrates the reduction of false-positive "Critical" alerts.
2. **CVE-2024-002 (Second from Left):** Shows a moderate CVSS (7.5). But because it is a Public-Facing and Highly Critical asset, VulnSight correctly escalates the risk to 85.
3. **CVE-2024-005 (Far Right):** Shows a vulnerability that is Critical in both metrics (CVSS 9.5 and ML Risk 98), proving that your model does not blindly reduce scores, but accurately identifies true threats.

B. System Reliability

The Universal Fallback Engine was subjected to black-box testing by intentionally revoking API keys and simulating network drops. In 100% of failure simulations, the Flask orchestrator avoided crashing and successfully routed the output to the local triage advisory, ensuring the final PDF report was always delivered to the end-user.

VI. Conclusion and Future Scope

The VulnSight platform successfully addresses the critical gaps in modern vulnerability management by engineering a unified, context-aware reconnaissance and remediation framework. By integrating the automated mapping capabilities of the WebScout engine, VulnSight eliminates traditional silos between proactive reconnaissance and threat alerting [4]. Furthermore, the implementation of a Random Forest Machine Learning model allows the system to synthesize baseline CVSS scores with environmental factors, yielding a dynamic "Real Risk" score [2].

By leveraging Generative AI, the platform autonomously translates complex vulnerability data into layman-friendly, technology-specific patch management strategies [5].

Future Scope:

Future iterations of VulnSight will focus on:

1. ***Predictive Assessment for Critical Infrastructure:*** Training the ML model on localized threat actor tactics for Cyber-Physical Systems [1].
2. ***Automated Patch Deployment:*** Transitioning the AI engine from generating textual advice [5] to generating and testing safe Infrastructure-as-Code (IaC) scripts for direct execution.
3. ***Continuous Monitoring:*** Upgrading the system to a continuous monitoring daemon that alerts administrators only when a delta in the infrastructure state is detected [4].

REFERENCES

[1] Okoebor, M. (2025). "An AI-Based Framework for Predictive Vulnerability Assessment and Risk Prioritization in Critical Infrastructure Systems." *IDEAS/RePEc*.

[2] "Automatic CVSS-Based Vulnerability Prioritization and Response with Context Information and Machine Learning." (2025). *MDPI*.

[3] "Integrated Risk Scoring and Exploit Prediction for Cyber-Physical Power System Vulnerabilities." (2026). *ResearchGate*.

[4] "AutoRecon-SOC: Design and Implementation of an Automated Reconnaissance and SOC-Oriented Threat Alerting Framework." (2025). *Jetir.Org*.

[5] "AI-Powered Vulnerability Detection and Patch Management in Cybersecurity." (2026). *MDPI*.